

사이버보안·AI 안전 기술동향 분석보고서

보고서 상태: 자료 기반 생성본

생성 기준일: 2026-09-23

분석 범위: AI 안전·보안·공급망·거버넌스·양자내성암호

1. 정책결정자용 핵심 판단

AI 안전은 사이버보안의 하위 항목이 아니라 모델·데이터·도구·사용자·사회적 영향까지 포함하는 별도 위험관리 축이다. 동시에 AI가 공격 자동화와 방어 자동화 양쪽을 가속하므로 보안 운영체제와 AI 거버넌스를 통합해야 한다.

2. 확인된 자료와 해석

확인된 자료: NIST는 2026년 4월 중요 인프라 대상 Trustworthy AI RMF Profile 개념노트를 공개했고 AI RMF 1.0 개정을 진행 중이다.

확인된 자료: CISA는 AI를 중요 인프라 보안과 연결해 다루는 공식 자료를 제공한다.

분석 해석: AI 도입 전 사전 인증만으로는 부족하며 운영 중 모니터링, 사고보고, 모델·데이터 공급망 추적이 필요하다.

3. 기술동향

1. 프롬프트 인젝션·모델 탈취·데이터 오염·에이전트 권한오용이 주요 위협으로 부상
2. 모델 카드와 레드팀을 넘어 배포 후 지속 평가·감사로그 요구 확대
3. AI 보안과 기존 클라우드·소프트웨어 공급망 보안의 경계가 축소
4. 중요 인프라와 공공서비스는 신뢰성·복구가능성·책임소재가 핵심

4. 국가 R&D 및 정책전략

국가 AI 안전성 시험·평가센터 구축

공공 AI 조달에 위험분류·감사로그·사고보고 조건 반영

모델·데이터·오픈소스 의존성 SBOM/AI-BOM 체계화

보안 연구자·레드팀·법제도 전문가의 공동 실증

5. 사업화·인재

AI 보안 테스트, 모델 관측성, 권한관리, 규제 대응 문서화가 독립 시장으로 성장한다. 인재는 ML 엔지니어와 보안 엔지니어를 분리하기보다 AI 시스템 위협모델링과 평가를 수행할 수 있도록 교차훈련한다.

6. 우선 실행과제

1. 중요 인프라용 AI RMF 프로파일 국내화
2. 공공 조달용 AI 안전성 평가 체크리스트
3. 에이전트 권한·도구 호출 보안 실증

4. 사고·취약점 신고와 모델 업데이트 체계 마련

7. 주요 출처

NIST AI RMF (<https://www.nist.gov/itl/ai-risk-management-framework>)

CISA Artificial Intelligence (<https://www.cisa.gov/ai>)

OWASP GenAI Security Project (<https://genai.owasp.org/>)

NIST Post-Quantum Cryptography (<https://www.nist.gov/pqc>)

10. 출처 분석: AI 도입은 OT에서 안전문제로 바뀐다

CISA와 국제 파트너의 2025년 OT 가이드는 AI를 OT에 통합할 때 안전·보안·신뢰성을 동시에 지켜야 하며 위험기반 접근이 필요하다고 제시한다. IT 환경의 모델 정확도만으로는 물리설비의 안전을 판단할 수 없다는 뜻이다. 운영 중 모델 변경, 센서 오류, 통신 단절, 잘못된 자동화 명령을 포함한 실패모드를 평가해야 한다.

NIST AI RMF의 중요 인프라 프로파일 논의는 AI 위험관리를 모델 개발 단계에 한정하지 않고 조직의 운영·책임·복구체계와 연결한다. 국내 정책은 인증서 하나를 발급하는 방식보다 위험분류, 책임자, 로그, 테스트, 사고보고, 업데이트 승인으로 구성된 운영통제를 요구해야 한다.

11. 위협모델과 통제

1. 데이터 오염·프롬프트 인젝션: 입력 검증, 출처표시, 권한분리
2. 에이전트 권한오용: 도구별 최소권한과 인간승인
3. 모델·오픈소스 공급망: 버전 고정, SBOM/AI-BOM, 재현 가능한 빌드
4. OT 오판: 안전제어와 AI 제어 분리, fail-safe와 수동복귀
5. 사고 이후: 감사로그·증거보존·신속한 모델 롤백

12. 정책 권고

고위험 공공 AI는 도입 승인보다 운영감사와 사고학습을 중심으로 관리한다. 조달계약에 모델 업데이트 통지, 취약점 신고, 데이터 사용범위, 로그 제공, 서비스 중단·복구 의무를 명시해야 한다.